Security review

w2mcp (anymcp)

Prepared 26 October 2026 | Fix verification

Reviewer: Kartik Bhardwaj

1. Executive summary

Agent-permissions review of w2mcp (anymcp), a CLI and hub that generate MCP servers from API docs or OpenAPI specs. The review was run by a fresh, independent Claude Code 2.1.283 session (claude-opus-5-5) with ChatNoir v0.4.1 installed as a project skill and loaded by name. It confirmed three issues by source reading: an API title that becomes code in every generated server, tool output that could drive writes in the w2mcp ask loop without approval, and a hub tool that could silently replace a trusted server. Follow-up work reproduced the first two at runtime with synthetic inputs and a scripted model. Commit 340f83a fixes all three. Both runtime reproductions now fail to trigger and legitimate behavior is preserved. Two candidates remain unresolved. Four were dismissed in the review, two are recorded here.

Recorded results: 7 findings; 2 unresolved, 3 fixed and 2 dismissed.

No open vulnerability has been confirmed in the supplied findings. This is not an all-clear; review unresolved items and coverage gaps.

Unresolved items need further investigation. Their assigned severity does not make them confirmed issues.

Next actions

Recommendations only; these changes and follow-up checks have not been performed by exporting this report. Resolve the detailed proof gaps before closing an item.

Finding / status	Recommended action and verification
W2MCP-04: Further review needed	Pin base_url to the spec or docs origin, or require confirmation when they differ. Never forward a token to a host the user has not confirmed.
W2MCP-05: Further review needed	Treat extraction output as untrusted. Validate base_url against the docs origin and show a diff before generating.

2. Scope and method

Review coverage	Recorded scope
Reviewed files	7
Deferred / skipped files	0 / 0
Coverage status	Limited review; see assessment boundaries below
Review method	Fix verification; evidence and verification are described below.

Declared scope and limitations

Scope: the agent-permissions focus of ChatNoir's guided first review. Authentication of the hub HTTP mode and web/server.ts was noted as out of scope and not assessed.

Method: a fresh headless Claude Code session did the source review. It used Read, Grep, Glob, the Skill tool and four read-only PowerShell commands (git metadata, file listing, ChatNoir first-review). No permission denials occurred. Runtime reproductions and fixes were done afterwards in a separate session.

Runtime evidence uses synthetic local inputs and a scripted model. It does not measure how often real models follow injected text.

Not read by the review session: drift-cli.ts, gen-cli.ts, store.ts, clean.ts, render.yaml, fly.toml. No dependency or secret scanning.

The ChatNoir baseline scan returned 0 candidates on this TypeScript project. Its agent rule families are Python AST rules, so all findings came from the guided source review.

Conclusions apply only to the recorded scope and evidence. No overall application security grade is assigned. This document presents supplied review results; generating it performs no additional testing.

3. Detailed findings

W2MCP-01: Untrusted API title becomes executable code in every generated server

Fix verified within stated scope | Severity: High | Evidence confidence: High

Source location: src/generate.ts:117

Classification: CWE-94

Evidence

1. Found by a fresh, independent Claude Code 2.1.283 session (claude-opus-5-5) that loaded ChatNoir v0.4.1 by name. It ran no target code. Its only commands were read-only: git ls-files, rev-parse and status, a file listing, and ChatNoir's own first-review helper.

2. At 7672f5d, generateServer spliced model.api_name unescaped into a block comment, a double-quoted string and a template literal of server.ts. model.ts only checks that api_name is a string.

3. openapi.ts copies spec.info.title verbatim into api_name. The docs path takes it from LLM output.

4. Runtime reproduction (test-api-name-injection.mjs): a synthetic spec whose title closes the comment and calls process.getBuiltinModule('fs').writeFileSync wrote the marker file when the generated server started under tsx, as w2mcp starts servers. The same test on 340f83a wrote nothing.

Failure path and impact

1. An attacker publishes or controls an OpenAPI spec (or docs page) with a crafted title

2. A user or agent runs w2mcp import or new, or calls the hub tool w2mcp__create, on that source

3. generateServer writes the title into server.ts as code

4. The hub, verify step or gateway starts the server with the full process environment, and the payload runs

Recommended remedy

Pass api_name through codeSafeName (letters, digits and a small punctuation set) before splicing it into generated code. Keep JSON.stringify for every other spliced value.

W2MCP-02: Tool output can drive state-changing tool calls in w2mcp ask without approval

Fix verified within stated scope | Severity: High | Evidence confidence: High

Source location: src/use-cli.ts:253

Classification: CWE-862

Evidence

1. Found by the same fresh Claude Code session: w2mcp ask feeds tool results back to the model as role:tool messages and runs whatever call it proposes next, including [UNVERIFIED WRITE] tools and w2mcp__create.

2. Runtime reproduction (test-agent-tool-output.mjs): a local fake chat API returned a message instructing the assistant to archive #general. A scripted OpenAI-compatible model obeys such text. At 7672f5d the archive endpoint was hit 1 time. On 340f83a it was hit 0 times, while the legitimate read (1) and the final answer still happened. With --yes (explicit human pre-approval) the archive ran once, confirming the gate is what changed the outcome.

Failure path and impact

1. A tool's upstream API returns attacker-controlled text

2. w2mcp ask passes that text back to the model

3. The model proposes a write or w2mcp__create

4. At 7672f5d the call ran with no human check

Recommended remedy

Require a human yes at the terminal for [UNVERIFIED WRITE] tools, destructiveHint tools and w2mcp__create. Fail closed when stdin is not a TTY. --yes opts in explicitly.

W2MCP-03: w2mcp__create silently replaced an existing registered server

Fix verified within stated scope | Severity: Medium | Evidence confidence: Medium

Source location: src/hub.ts:108

Classification: CWE-639

Evidence

1. Found by the same fresh session: createServerFromSource overwrote reg[name] and the live downstream connection with no existence check, so any connected agent could swap a trusted server, and the change persisted in registry.json.

2. 340f83a throws before fetching the source when the name exists in the registry or among live downstream servers.

Failure path and impact

1. An agent connected to the hub (possibly steered by injected text) calls w2mcp__create with the name of an existing server

2. At 7672f5d the trusted server was replaced by one generated from the new source

Recommended remedy

Refuse to replace an existing name from a tool call. Replacement stays an operator action (edit registry.json).

W2MCP-04: Credential exposure through an attacker-specified base_url

Further review needed | Severity: Medium | Evidence confidence: Low

Source location: src/openapi.ts:129

Classification: CWE-201

Evidence

1. An attacker spec sets base_url from servers[0].url, and its title decides which *_TOKEN env var the server reads.

Unresolved questions

1. Needs proof that a matching token exists in the hub's environment in a real deployment. The W2MCP-01 and W2MCP-03 fixes remove the code and replacement paths, not an attacker-chosen base_url for a new name.

Recommended remedy

Pin base_url to the spec or docs origin, or require confirmation when they differ. Never forward a token to a host the user has not confirmed.

W2MCP-05: Docs path may let injected page text shape the generated model

Further review needed | Severity: Low | Evidence confidence: Low

Source location: src/extract.ts:1

Classification: CWE-1427

Evidence

1. w2mcp new <url> asks an LLM to extract api_name, base_url and endpoints from page text an attacker may control.

Unresolved questions

1. Depends on a live model following injected text in the page. Not tested.

Recommended remedy

Treat extraction output as untrusted. Validate base_url against the docs origin and show a diff before generating.

W2MCP-06: Path traversal through the create name

Dismissed | Severity: Info | Evidence confidence: High

Source location: src/hub.ts:110

Classification: CWE-22

Evidence

1. Candidate: the name passed to w2mcp__create becomes a directory under out/.

Controls and limits on impact

1. The name is sanitized with [^\w-]+ to '-' before joining the path, so separators and dots cannot traverse.

Recommended remedy

None.

W2MCP-07: Code injection through endpoint names, paths, params, headers, error meanings or noise fields

Dismissed | Severity: Info | Evidence confidence: High

Source location: src/generate.ts:53

Classification: CWE-94

Evidence

1. Candidate: other model fields are spliced into generated code too.

Controls and limits on impact

1. Every one of those values is emitted through JSON.stringify, tokenEnv is sanitized, and error codes are validated as numbers in model.ts.

Recommended remedy

None.

4. Verification and remaining work

W2MCP-01: Fix verified within stated scope

Verification method: Executed local test

Before fix: payload executed on server start (marker written). After fix 340f83a: marker not written. The calendar demo server regenerates byte-identical (169,153 bytes), so legitimate names are unchanged.

The recorded verification supports this fix only within the stated test conditions. Deployment and broader security coverage require separate confirmation.

W2MCP-02: Fix verified within stated scope

Verification method: Executed local test

Scripted model, synthetic local API: 1 injected write before, 0 after. Legitimate read and answer preserved. Real-model susceptibility was not measured.

The recorded verification supports this fix only within the stated test conditions. Deployment and broader security coverage require separate confirmation.

W2MCP-03: Fix verified within stated scope

Verification method: Source inspection

Guard added before any fetch or write. Confirmed by source reading only. No runtime test was run because the hub module starts its transport on import.

The recorded verification supports this fix only within the stated test conditions. Deployment and broader security coverage require separate confirmation.

W2MCP-04: Further review needed

Verification method: Source inspection

Not reproduced.

Next step: resolve the recorded proof gaps before presenting this item as confirmed.

W2MCP-05: Further review needed

Verification method: Not executed

Not tested against a live model.

Next step: resolve the recorded proof gaps before presenting this item as confirmed.

W2MCP-06: Dismissed

Verification method: Source inspection

Dismissed by source reading.

W2MCP-07: Dismissed

Verification method: Source inspection

Dismissed by source reading.

Evidence reference

The identifiers below bind these results to the reviewed source snapshot. They support reproduction and do not establish assessment completeness.

Report data version: ChatNoir 0.4.1

Source inventory SHA-256: ac5aafbbb0601683935861c5311fb7d422cda47859183136f075ac5c275d3232

Recorded Git revision: 340f83aa15e9c08892beffa54ecbc050c688a30d

Source checkout: Not recorded

src/generate.ts | 13367 bytes | SHA-256 84c1f427f0e1e48b8a8908a7512fd191a078aafdd910947b8c286077f756448d

src/hub.ts | 10415 bytes | SHA-256 ffc7caa87881931bcc9554254acfc1f951f8a51115431aa3c40a8af1486f0b32

src/model.ts | 2772 bytes | SHA-256 656f908ac2b0fb17c3d4ced9c40de9baf9b8f5d6934fa7620e458901175ba450

src/openapi.ts | 9317 bytes | SHA-256 21870fbdf458255839f8d7ae20fee8dd5d738a6b83caf0eb46dd00f5e8babd21

src/use-cli.ts | 19444 bytes | SHA-256 66a796048ea8ceb37374b850975668762ebdf7b9e4ffbf18175b994f0856376b

test-agent-tool-output.mjs | 4657 bytes | SHA-256 ee5778175936bd65107aa384e28bb114ba82422a83282712baf6e82ab400c942

test-api-name-injection.mjs | 1734 bytes | SHA-256 c2433657df3ae5ed7feac88120d57ddde53f679e42c19d6363a38dacddf37a16

This is a point-in-time, scoped review record, not a security certification. Review confidential report contents before sharing.